

Northside Home Goods

Incident Response Plan (IRP)

Version: 1.0 | Scope: Security Events and Data Breaches

1. Purpose

This Incident Response Plan gives Northside Home Goods a repeatable process for detecting, containing, and recovering from cybersecurity incidents. The goal is to reduce business interruption to our retail and e-commerce operations, protect forensic evidence, meet cyber insurance notification requirements, and avoid making a bad situation worse by acting without a plan.

This document should be stored offline as a printed copy and reviewed at least annually. Every member of the Incident Response Team should read it before an incident happens.

2. Incident Response Team and Roles

- **Operations Manager (Incident Commander):** Coordinates the overall business response, approves all external communications, and serves as the primary contact for the cyber insurance broker and any external counsel. All major decisions about containment, communications, and vendor engagement go through this role.
- **IT Lead (Internal or Outsourced):** Leads technical containment, preserves forensic evidence, coordinates with vendors and service providers on the technical side, and oversees system restoration.
- **HR Liaison:** Manages internal employee communications and handles HR coordination if employee data is involved in the incident.

3. Escalation and Cyber Insurance Notification

Time matters during a breach. Move quickly.

1. Any employee who suspects an incident — a ransomware lock screen, an unusual payment redirect, a compromised email, a POS terminal behaving strangely — should immediately:

- Disconnect the affected device from the network (unplug the ethernet cable or turn off Wi-Fi).
- **Do NOT shut the machine down** — turning it off destroys forensic memory that may be critical to understanding what happened.
- Contact the IT Lead immediately by phone.

2. If the IT Lead confirms a material incident (ransomware, data breach, Business Email Compromise), the Operations Manager must notify the cyber insurance provider within 24 hours of confirmation.

■ **Important: Do not hire external forensic firms, legal counsel, or ransomware negotiators without written approval from the cyber insurance claims adjuster first. Doing so without approval may void coverage.**

4. Phase I: Preparation and Detection

Preparation

- Maintain updated offline backups and a printed copy of this IRP.
- Confirm that the insurance broker's emergency contact number is accessible offline.
- Ensure endpoint protection (EDR/AV) is active and monitored on all devices.
- Review admin account access quarterly — make sure only current employees have it.

What to Watch For

- EDR or antivirus alerts, especially those flagging persistence or lateral movement.
- Unusual after-hours logins or logins from unexpected locations.
- Customer reports of fraudulent charges, phishing emails appearing to come from the company, or unexpected purchase confirmation emails.
- Unexpected changes to email forwarding rules or payment account details.
- POS terminals or registers behaving unexpectedly.

5. Phase II: Containment

Short-Term Containment (do this immediately)

- Isolate compromised endpoints from the network — unplug them or disable network access at the switch level if possible.
- Disable compromised user accounts in M365 or Active Directory. Revoke active session tokens.
- Take screenshots or photos of any error messages, ransomware screens, or suspicious activity before touching anything else.
- Do not wipe or reimage affected machines until the IT Lead confirms forensic evidence has been preserved.

Longer-Term Containment

- Rebuild compromised machines from clean baseline images once forensic evidence is secured.
- Force a global password reset for all administrative accounts and any accounts in scope of the incident.
- Apply any missing patches that contributed to the initial compromise.
- Review firewall rules and remote access settings to confirm no new backdoors were created.

6. Phase III: Communication

Communication during an incident needs to be controlled and intentional. Uncoordinated statements — even well-meaning ones — can complicate the response, affect legal exposure, and create confusion.

Internal Communication

- The Operations Manager is the single point of communication to employees. IT leads technical updates upward; the Operations Manager decides what gets shared more broadly and when.
- Provide a brief update to staff once the situation is stabilized — employees hearing nothing often fill the gap with speculation.
- Do not discuss incident details over personal devices, personal email, or messaging apps. Assume corporate email and systems may be compromised.

External Communication

- **Insurer:** Notify within 24 hours of confirming a material incident (see Section 3). Do not engage external vendors without insurer approval.
- **Customers:** If customer data was exposed, the Operations Manager (with legal guidance if available) determines the timing and content of customer notification. Many states have data breach notification laws with specific timelines.
- **Payment processor:** If card data may have been involved, notify the payment processor immediately. They have their own breach response protocols.
- **Vendors:** If a third-party vendor was involved in or affected by the incident, notify them promptly so they can investigate on their end.
- **Do not** make public statements, post on social media, or contact media without coordinating with the Operations Manager first.

7. Phase IV: Eradication and Recovery

Eradication

- Verify that all malicious payloads have been removed — including backdoor accounts, unauthorized email forwarding rules, and persistent malware.
- Scan rebuilt systems before bringing them back online.
- Confirm that the initial entry point has been closed — whether that was an unpatched system, a compromised credential, or a malicious email attachment.

Recovery

- Restore business data from the most recent verified clean backup. **Do not restore directly over a compromised system** — restore to a clean environment.
- Bring retail POS systems and the e-commerce platform back online in priority order, monitoring closely for signs of reinfection.
- Confirm with end users that systems are functioning normally before closing the incident.

8. Phase V: Post-Incident Review

Within two weeks of resolving the incident, the Incident Response Team meets to review what happened and make sure it doesn't happen again.

- Document the root cause — how did the attacker get in, and how far did they get?
- Evaluate the response — what worked, what was slow, what was unclear?
- Assign corrective actions with owners and due dates (new tools, updated training, policy changes).
- Update this IRP based on lessons learned.
- Provide a brief written summary to leadership.

Northside Home Goods is a fictional company created for portfolio purposes. All policies in this folder are fictional and don't represent any real company or client. This isn't insurance, legal, or underwriting advice.

Policy template note: This sample policy was adapted conceptually from SANS Institute policy templates. It is not an official SANS document, and SANS Institute retains all rights to its original materials.